**Team Members:** Parker Cummins, Lalit Lakamsani, Jenessa Lu, Vamsee Vusuwandla

Work Flow Diagram: Attached

Step 1: Design

Define the risk question, input scope, target environment, and required rating output.

- Weakness: SMB signing weakness
    - Asset group W05 contains four file servers.
    - SMB1 is disabled.
    - SMB signing is required on three servers.
    - FILE04 does not require SMB signing.
    - The servers host departmental files, including Finance and HR shares.
- Risk Question: What risk does the lack of required SMB signing on FILE04 pose to Northridge Services? Eg: potential SMB relay, man in the middle attacks, network accessibility, sensitivity of hosted data
- Input Scope: Microsoft SMB security guidance, FILE04 configuration, relevant network controls, business impact evidence
- Target Environment: Northbridge Services, specifically W05/FILE04
- Required Rating Output: High, Medium, Low, Insufficient Evidence/ Review, Not Applicable
- Design Change (Prompt Chaining to Autonomous Agent): For our initial design, we used a prompt chaining approach with fixed stages for loading the case, gathering the evidence, assessing applicability and impact, applying the rating policy, and generating the report. However, during implementation, we decided to build a tool-calling loop, run_agent. Based on the evidence gathered so far, the model chooses the next tool and its arguments, rather than following fixed stages. Our system prompt still suggests an order, but the code does not enforce it. The code limits the agent by capping the run at 10 iterations, only allowing the defined tools, and blocking the report until environment and guidance evidence are retrieved. The rating policy is applied in code rather than by the model.

Create a rating policy for assigning High, Medium, or Low risk using applicability and impact.

- High: Supported access exposes critical data and services, such as financial or administrative access
- Medium: Supported access exposes business information that will disrupt the department's services, but limited in scope to be outside of critical services and operations.
- Low: Supported access is limited to only non-sensitive information that has minor consequences if exposed
- Insufficient Evidence/ Review: Not enough information or evidence to support a rating and/or needs an internal review
- Not Applicable: Evidence shows a required attack prerequisite is absent (e.g., SMB not reachable), so no rating is assigned

Identify model, code, tool, and human steps; show evidence flow, decision points, and analyst review.

- Design Pattern: Autonomous agent (tool-calling loop) - The model chooses the next tool and its arguments from the evidence gathered. The report is blocked until the environment and guidance evidence are retrieved, and it applies the rating policy in code. Finally, a human reviews the final assessment and makes the last judgement.
- Specific model: Ollama gpt-oss:20b
- Code: Python 3.13.16
- Tools: RAG Search, CISA KEV, Check Attack Applicability, Data Synthesizer/ Reporter
- Human Steps: Review over facts, evidence, policies, and actions produced by the agent.
    - Model: Select necessary tools and construct basic queries, evaluate tool output
    - Code: Load environment, read settings/configuration
    - Tool: Retrieve all needed evidence, CVE lookup, KEV checks
    - Human: Verify final output and pass approval (yes or no)
- Evidence Flow:
    - Input says SMB is enabled, doesn't require credentials to enter
    - Model selects lookup tool and constructs a query for the specific tool/vulnerability
    - Tool returns the versions affected, the details of the vulnerability, all severity information
    - Model then reviews the tool outputs
- Decision Points:
    - Is env data sufficient:
        - Check to see if SMB config, Windows version, network info is enough
        - If so, continue. Otherwise, request/flag
    - Does a vulnerability apply:
        - See if a specific vuln actually applies or not
        - If yes, note it. Otherwise, keep looking
    - How severe is the risk:
        - What could happen if a threat is applied?
        - Apply group policy (in table below)
    - Is evidence sufficient?:
        - Does the aggregated data support the final conclusion?
        - If yes, produce a rating. If not, re-run everything
- Analyst Review: :
    - Verify evidence to see that sources used are legit/proper
    - Review final rating to confirm that it follows the guidelines/definition set
    - Handle exceptions and shut down tool before it continues
        - Can also fail assessment at the end

Explain each tool's purpose, inputs, outputs, source attribution, and role in the risk decision. The examples on the next page are optional; use relevant tools from the list or create your own.

- RAG Search | rag_search():

    - Purpose: retrieve environment facts and SMB security guidance
    - Input: query, collection, top_k
    - Output: matching passages (environment, guidance), each with a source ID
    - Source Attribution: environment passages cite the asset or evidence ID and are always labeled simulated, guidance passages cite the original URL and the date the page was saved
    - Role: provides the applicability facts, impact facts, attack;s prerequisites from the guidance collection
- CISA Kev | lookup_cisa_kev():
    - Purpose: Check whether a specific CVE is in CISA KEV's catalog.
    - Input: cve_id
    - Output: The matching catalog entry from CISA KEV
    - Source Attribution: The CISA KEV catalog
    - Role: Add the known exploitation context for all CVE related queries, and if it is applicable to the risk rating
- Check Attack Applicability | check_attack_applicability():
    - Purpose: check whether an SMB relay attack is applicable based on the available environment evidence and attack prerequisites.
    - Input: smb_signing_not_required, smb_reachable, relay_prerequisites_met, unsigned_connection_possible (True, False, or None)
    - Output: applicability status (applicable, not_applicable, or insufficient_evidence), evaluated conditions, missing evidence, and whether analyst review is required.
    - Source Attribution: uses evidence retrieved through RAG Search from the Northbridge environment and Microsoft SMB security guidance. The function itself does not retrieve sources or verify citations.
    - Role: compare attack prerequisites against known environment conditions, distinguish confirmed facts from unknowns, and determine whether sufficient evidence exists to support a risk rating.
- Data Synthesizer/ Reporter | generate_report():
    - Purpose: synthesizes information from the other tools into a report format
    - Input: asset id, threat description, evidence, findings, business impact, actions
    - Output: a json assessment of the asset
    - Source Attribution: The original ids, URLs, data, dates, and evidence
    - Role: Decision Maker: takes the report from the Data Synthesizer/ Reporter and makes a decision on the rating Organize the findings to explain the rating and decision making of the agent in producing the report it has concluded on

Create and justify a rating policy based on the applicability of the threat to your environment and the impact it has on your network.

| Applicability | Rating |
| --- | --- |

| | |
|---|---|
| Supported path exposes sensitive data that is administrative or applies to critical services | High |
| Supported path exposes departmental data bounded to the business | Medium |
| Supported path exposes minor consequential data | Low |
| Evidence is missing or conflicting in applicability | Insufficient Evidence |

- Show what happens when a lookup fails or a decisive fact is unknown, including when the workflow stops.
  - Permitting retry
  - Workflow stops when there is insufficient evidence
  - Stopping rules
    - Missing FILE04
    - Conflict with clarification lookup
    - Tools requests rejected
    - Unresolved decisive questions after tool calls
    - Workflow proceeds to review

- Define a simple acceptance test stating how you will verify that the complete workflow produces a supported rating or an explicit insufficient-evidence status when necessary.
  - The SMB case is loaded with a correct environment snapshot
  - The model makes at least one valid tool-selection or query-construction decision
  - Code executes both an environment lookup and external evidence lookup
  - The saved output follows the policy, supporting evidence, reports unknowns, and recommends action steps
  - External users analyze and verify the citations and decisions made

Tool Evaluation

| Test | Expected | Actual | Result |
|---|---|---|---|
| Applicability changes | Applicable, not applicable, or insufficient evidence | Applicable, not applicable, or insufficient evidence | PASS |

| | | | |
|---|---|---|---|
| Business impact changes | High, Medium, Low | Record after running | PASS |
| Missing evidence | Insufficient Evidence | Record after running | PASS |
| CISA API failure | Unavailable, no fabricated evidence | Record after running | PASS |